

Burp Suite Intruder

Complete Reference Guide

1. Grep Match vs Grep Extract

Both features live under the **Settings** → **Grep** tab in Burp Intruder, but they serve very different purposes. Understanding when to use each is key to efficiently analyzing attack results.

Grep – Match

What it does: Scans each response and checks whether a specific string or pattern exists in it. It adds a boolean column to the results table — either the string was found (✓) or it wasn't (✗).

When to use it: Use Grep Match when you already know what a success or failure looks like, and you just want to flag which responses contain it. It answers a yes/no question: *"Does this response contain the word 'Invalid'?"*

Scenario	String to Match
Username enumeration via error	Invalid username
Detecting account lockout	Your account is locked
Finding successful login	Welcome back
Detecting WAF block	Access Denied
SQL injection success	syntax error

Grep – Extract

What it does: Extracts and displays a specific piece of text from each response. You define a region (by start/end delimiters) and Burp will pull that exact text out and show it as a column in the results table.

When to use it: Use Grep Extract when you need to see a value that changes between responses — not just whether something exists, but *what* it is. It answers the question: *"What does this specific part of the response say?"*

Scenario	What to Extract
Harvest CSRF tokens per request	value="..." from hidden input
Compare error messages between payloads	The error message text
Extract session IDs from responses	Session cookie value
Capture dynamic redirects	Location header value
Read reflected payload back	The echoed user input

Quick Comparison

	Grep Match	Grep Extract
--	------------	--------------

Output in results	Checkbox (✓ / ✗)	The actual extracted text
Input needed	A string or regex	Start + end delimiters
Answers the question	"Is X in the response?"	"What does X say?"
Best for	Flagging anomalies	Harvesting dynamic values
Can use regex?	Yes	No (delimiter-based)

2. Burp Intruder – Settings Reference

Intruder's Settings tab (accessible from the attack window) contains several groups of options that control how the attack behaves. Below is a description of each group, what it does, and when you should use it.

Request Headers

Update Content-Length

What it does: Automatically recalculates and updates the Content-Length header after each payload is inserted.

When to use: Almost always leave this ON. Without it, requests with body payloads may be malformed and rejected by the server.

Set Connection: close

What it does: Adds a 'Connection: close' header to each request, telling the server to close the TCP connection after the response.

When to use: Useful when you're having issues with keep-alive connections hanging. Turn on if responses are slow or stalling.

Request Engine

Number of threads

What it does: Controls how many concurrent requests Intruder sends simultaneously.

When to use: Increase for speed on stable targets. Decrease (to 1) for stealthy attacks or to avoid triggering rate limits / lockouts.

Number of retries on network failure

What it does: How many times Burp will retry a request if it gets a network error.

When to use: Increase if the target is unstable. Set to 0 if you want to know immediately about failures without wasting time retrying.

Pause before retry (ms)

What it does: How long Burp waits before retrying a failed request.

When to use: Increase if the server needs time to recover after an error.

Throttle between requests (ms)

What it does: Adds a fixed delay between each request. Can also be set to a random range.

When to use: Use this to slow down your attack and avoid detection, rate limiting, or account lockouts. Essential for the account locking lab.

Start attack at result number

What it does: Allows you to resume an interrupted attack from a specific request number.

When to use: Useful if your attack was paused mid-way and you don't want to restart from the beginning.

Attack Results

Store requests / Store responses

What it does: Saves the full raw request and/or response for each payload attempt.

When to use: Enable both when doing manual analysis — you can right-click any result and inspect it fully. Disable to save memory on very large attacks.

Make unmodified baseline request

What it does: Sends one extra request with no payload at all, so you have a baseline response to compare against.

When to use: Always useful. Helps you immediately spot what 'normal' looks like vs. an anomalous response.

Use denial-of-service mode

What it does: Sends requests without reading the response, maximizing speed.

When to use: Only for actual DoS testing (with permission). Never use during enumeration — you won't see any results.

Grep – Match

Match string / regex in response

What it does: Adds a results column that flags (✓/X) whether each response contains a specified string or regex pattern.

When to use: Use when you know what a success/failure looks like. E.g., match 'Invalid password' to find the one response that does NOT contain it — that's your valid credential.

Grep – Extract

Extract value from response

What it does: Defines start/end delimiters to extract a portion of text from each response and show it as a column in results.

When to use: Use when harvesting dynamic values like CSRF tokens, error messages, or session identifiers that change per response.

Grep – Payload Reflection

Flag reflected payloads

What it does: Adds a column indicating whether the payload you sent appears (is reflected) back in the response.

When to use: Primarily useful for XSS testing. If the payload is reflected unencoded in the HTML, it may be injectable.

Redirections

Never / Always / In-scope only / Ask

What it does: Controls whether Burp follows HTTP redirects (301, 302, etc.) during the attack.

When to use: Set to 'Always' if you want to see the final destination page (e.g., a logged-in dashboard). Set to 'Never' if the redirect itself is the indicator you're looking for — e.g., a 302 response after a successful login.